

Information Security Policy (SOC 2)

Version: 1.2

Date: May 2026

Confidentiality: Internal Use Only

#1. Purpose and Scope

The purpose of this Information Security Policy is to establish the foundation for securing Auditchain's information systems and data. This policy aligns with SOC 2 Trust Services Criteria for Security and Confidentiality. The scope of this policy includes all employees, contractors, and third-party vendors who access company systems or data.

#2. Access Control (CC6.1)

- Authentication Requirements: All employees must use multi-factor authentication (MFA) to access the corporate network, cloud infrastructure, and core applications.
- Password Policy: Passwords must be at least 12 characters long and must be changed every 90 days.
- Access Reviews: IT Management must conduct a review of user access privileges on a quarterly basis to ensure privileges remain appropriate.

#3. Risk Assessment (CC3.1, CC3.2)

- Annual Risk Assessment: The Security Team shall conduct a formal risk assessment at least annually to identify potential threats and vulnerabilities to the organization's information assets.
- Risk Mitigation: Management must evaluate identified risks and document a mitigation plan for any risk deemed "High" or "Critical."

#4. Incident Response (CC7.3)

- Incident Reporting: All personnel must report suspected security incidents to the Security Team within 24 hours of discovery.
- Incident Handling: The Incident Response Team must evaluate reported incidents, contain the threat, and formally document the root cause and remediation actions in the incident ticketing system.

#5. Vendor Management (CC9.2)

- Vendor Security Reviews: A security assessment must be performed on all critical third-party vendors prior to onboarding and annually thereafter.
- Data Processing Agreements: Vendors handling confidential or sensitive customer data must sign a Data Processing Agreement (DPA).

#6. System Monitoring (CC7.2)

- Log Collection: System, application, and network logs must be centrally collected, securely stored, and retained for a minimum of 12 months.
- Continuous Monitoring: Automated alerts must be configured to notify the Security Team of unauthorized access attempts or significant configuration changes in the production environment.

#7. Change Management (CC8.1)

- Change Approval: All changes to the production environment must be documented, peer-reviewed, and formally approved by engineering leadership prior to deployment.

- Testing: Changes must be successfully tested in a staging environment before being deployed to production.

#8. Data Security and Confidentiality

- Data Encryption at Rest: All sensitive customer data and credentials must be encrypted at rest using industry-standard encryption algorithms (e.g., AES-256).
- Data Encryption in Transit: All data transmitted over public networks must be encrypted using TLS 1.2 or higher.

#9. Policy Enforcement

Violations of this Information Security Policy may result in disciplinary action up to and including termination of employment or contract termination.